ITA CHALLENGE SPRINT · SEMANA 4 · TESTES E PROTÓTIPO V2

Testamos o protótipo contra a realidade — e ele mudou.

GerencIA V2: a comparação com o processo atual, os testes com casos que o motor nunca viu no ajuste, os resultados medidos, o que acertou, o que falhou e seus limites — e as mudanças que os testes forçaram, incluindo o comportamento seguro da IA.

688 eventos avaliados (650 da planilha + 38 de coleta ao vivo) · 15/15 casos do gabarito · 98,8% de concordância de nível · dados fictícios (declarado)

Protótipo V2

O que mudou da V1 para a V2

A V1 provou que roda; a V2 provou que resiste ao teste. Submetemos o motor aos 15 casos oficiais do gabarito (que não entram no ajuste), rodamos os dois motores — Python e navegador — evento a evento, e ligamos a captura ao vivo a estações reais: **38 usos de IA** entraram pela borda e foram avaliados pelo mesmo motor da base. O que os testes revelaram virou mudança: cache de DNS, classificação local por LLM on-premise e o par prompt↔resposta na captura.

Critério 01 · Aplicabilidade

Comparação com o processo atual

O processo atual da área é **revisão manual sobre planilha**: alguém lê os registros, julga caso a caso e anota. Três dores tornam isso inviável em escala:

dói hoje

Não escala

688 eventos a olho são horas de leitura; a cada nova semana, tudo de novo. O motor faz em ~2 s.

dói hoje

Sem o porquê

A planilha diz o nível, não a razão. Sem a cadeia de evidência, um alerta é opinião — não se audita nem se contesta.

dói hoje

Cego ao shadow AI

A planilha só tem o que alguém digitou. O uso de IA que acontece fora dela — a maior parte — é invisível.

Dimensão	Processo atual (manual)	Alternativa simples (só regras *ou* só LLM)	GerencIA (cascata)
Reaplicar a política a 650 eventos	horas, sujeito a cansaço	rápido, mas rígido (regras) ou caro e opaco (LLM)	**~2 s, com evidência**
Explica cada decisão	depende de quem olhou	regras: sim · LLM puro: não	**sim — regra + detectores + fingerprint**
Linguagem natural (pergunta do auditor)	manual	regras: não · LLM: sim	**sim, só no resíduo ambíguo**
Enxerga uso de IA fora da planilha	não	não	**sim — captura ao vivo (38 eventos)**
Custo por decisão	tempo humano	LLM puro: alto e recorrente	**quase zero (regra) + LLM só no resíduo**

Por que a cascata, e não uma alternativa simples

só regras

Auditável, mas rígida

Explica tudo, mas não entende a pergunta do auditor em português nem a paráfrase de um documento. Trava no inédito.

só LLM

Flexível, mas opaca

Entende linguagem, mas é caixa-preta (ruim para governança) e cobra por cada decisão — caro e recorrente.

cascata

As duas, e aprende

Regra decide e explica o comum; o LLM cobre só o resíduo ambíguo — e o que resolve **volta a ensinar** a regra, baixando o custo com o uso.

Ou seja: a cascata não é um enfeite técnico — é o que torna a solução **aplicável** numa área de governança, que precisa de decisão explicável e barata, sem abrir mão de entender linguagem natural.

Critério 02 · Casos representativos

O que foi testado — e o que ficou fora do ajuste

Dois conjuntos de teste, nenhum deles usado para calibrar o motor:

referência externa

15 casos oficiais do gabarito

A banca define o resultado esperado de cada um. São a **verdade de fora**: não ajustamos nenhuma regra para passar neles — eles existem só para dizer se o motor está certo. **15/15 reproduzidos.**

dados do presente

38 capturas ao vivo

Usos reais de IA em estações, recebidos pela extensão/coletor. Não são sintéticos e não calibram nada — entram pela borda e são avaliados pelo **mesmo motor** da base, marcados como `Coleta`.

Por que importam os casos de fora do ajuste: se o motor fosse calibrado para passar no gabarito, o 15/15 não provaria nada — seria memorização. Como os 15 casos e as 38 capturas **não tocam** nas regras, o resultado mede generalização real, não decoreba.

Cobertura dos 15 casos do gabarito

Varrem o espaço do problema — áreas, ferramentas, tipos e sensibilidades diferentes:

Caso	Área	Ferramenta	Informação	Esperado	Motor
CV01	Engenharia	IA Pública A	Chave/API secret	Crítico	✓
CV02	Financeiro	IA Pública B	Resultado financeiro não divulgado	Crítico	✓
CV03	Pessoas	IA Pública A	Folha/remuneração	Crítico	✓
CV04	Comercial	IA Pública B	Proposta comercial	Crítico	✓
… e mais 11 casos, de Crítico a Baixo — **15/15 reproduzidos**, nível e regra conferidos.					

Perfil das 38 capturas ao vivo

É preciso distinguir o que exercitou o **motor de classificação** (conteúdo) do que foi só **detecção de conexão** pelo sensor de rede — senão a contagem de ferramentas engana:

conteúdo avaliado

21 capturas · 3 ferramentas

Com conteúdo real, pela extensão: ChatGPT (15), Gemini (5), Grok (1), de 3 usuários. É o que de fato testa a classificação.

só conexão

17 capturas · detecção de rede

O sensor vê a conexão a domínios de IA e identifica a ferramenta (11 ao todo), mas **não** lê o conteúdo — por desenho.

Veredito do motor

No total: 15 Críticos (os CPF) e 23 Baixos — a mesma régua R01–R14 da base, sem ajuste para a coleta.

Testes automatizados

- **Sanidade (`testes.py`):** prova três afirmações centrais — o fingerprint reconhece um trecho colado e reformatado (e não confunde documentos distintos); os detectores validam de verdade (dígito verificador de CPF/CNPJ, Luhn de cartão), não alarmam em qualquer número; o motor é **monotônico** — piorar ferramenta ou classificação nunca reduz o risco.
- **Paridade (`testes_paridade.py`):** roda o motor Python e o motor JavaScript sobre os mesmos 650 eventos e compara **evento a evento**. Uma simulação que diverge do motor real mente — então exigimos paridade total antes de confiar na simulação de impacto do console.

Resultados obtidos

O que os testes mediram

15/15 casos do gabarito reproduzidos	**98,8%** concordância de nível (642/650)	**96,3%** concordância de regra (626/650)	**650/650** paridade Python × navegador
7/10 indicadores declarados que divergem	**6** achados de auditoria da base	**38** usos de IA capturados ao vivo	**688** eventos avaliados (650 + 38)

A concordância alta **não** é o objetivo final — os **1,2% em que o motor diverge da base** e os **7/10 indicadores** que não batem com o declarado são exatamente o valor: o motor concorda onde a base está certa e aponta, com evidência, onde ela erra.

Critério 03 · Honestidade

Acertos, falhas e limitações

acerto

Reproduz e explica

15/15 do gabarito, 98,8% da base, e cada decisão com a cadeia de evidência que a sustenta.

acerto

Acha o ponto cego

6 achados de auditoria e 7/10 indicadores divergentes — o que a revisão manual não via.

acerto

Vê o presente

38 usos reais capturados, com identidade do SO e origem (Planilha × Coleta) marcada.

As divergências — falha do motor ou da base?

Em **8 de 650 eventos (1,2%)** o motor diverge do nível da base, e **7 de 10 indicadores** declarados não batem com o apurado. Investigamos cada um: na maioria é a **base/rotulagem** que está frouxa (ex.: achado A-03, conteúdo não público numa ferramenta "aprovada só para público"), não o motor. Onde a dúvida é legítima do conteúdo (R07/R13), o motor **não crava** — marca para revisão. Divergência, aqui, é sinal — não bug.

Limitações que permanecem

Limitação	Situação
Sensor de rede vê a conexão, não o conteúdo (tráfego TLS)	por desenho — o conteúdo fica na extensão; MITM é a alternativa opt-in
DNS reverso não resolvia em CDN (Cloudflare/Google) e um IP compartilhado virava 11 IAs	**resolvido** — índice de IPs + cache de DNS como autoridade
Fingerprint não detecta paráfrase; varredura linear	pega recorte/colagem; em escala vira índice LSH (mesma matemática)
Paridade de hash FNV-1a (JS) × blake2b (Python)	pendente (fase 2); não afeta o motor de regras, que tem paridade total
Extração de conteúdo por site (APIs privadas mudam)	best-effort por ferramenta, com fallback genérico
Identidade exige usuário logado (serviço sobe no boot antes do login)	atribui ao usuário assim que alguém loga
6 das 14 regras nunca são acionadas na base (achado A-04)	sinal de regra morta ou lacuna de dado — vira revisão de política

Critério 04 · Ajustes e segurança

O que mudou após os testes, e o comportamento seguro da IA

É o critério que mais mexeu no protótipo. Os testes não só mediram acerto — **forçaram mudanças** e expuseram onde a IA precisa de freio. Aqui, segurança é por desenho, não promessa.

Mudanças que os testes forçaram

O teste revelou	Ajuste feito
Tráfego real: um IP de CDN compartilhado fazia uma busca virar várias IAs (falso-positivo)	**cache de DNS como autoridade** + índice de IPs — o ruído some
Classificar o texto livre mandaria conteúdo sensível à nuvem	**Nível 1 local (Qwen3 via llamafile)**, on-premise; só o resíduo sobe ao Claude
A captura guardava a pergunta sem a resposta — evidência pela metade	**par prompt↔resposta (`par_id`)**: a interação inteira numa unidade
A mesma busca repetida inundava o painel	**dedup por uso** — eventos repetidos não floodam a fila
A confiança do classificador vinha sempre 0	**corrigida**, e o serviço movido para porta dedicada
Atritos de instalação no Windows (alias da Store, execution policy, ACL pt-BR)	**resolvidos** no instalador durante os próprios testes

A cascata que não decide sem base

Nível 0 · borda

Detectores determinísticos

CPF/CNPJ (dígito), cartão (Luhn), credenciais por padrão. O valor sensível é mascarado na máquina; só tipo e contagem saem.

Nível 1 · on-premise

Qwen3 (llamafile)

Classifica tipo e sensibilidade do texto livre no servidor da empresa. O conteúdo não cruza o perímetro.

Nível 2 · nuvem

Claude (resíduo)

Só quando a regra não basta e o caso é inédito. O que resolve volta a ensinar a camada clássica.

O freio central: quando a camada 1 não resolve, o nível fica **provisório** — nunca é mostrado como certeza. A IA não preenche a lacuna com um palpite; ela **declara** a lacuna.

Salvaguardas de comportamento seguro

Salvaguarda	Como funciona	O que previne
Mascaramento na borda	CPF/cartão/credencial viram `[MASCARADO]` antes de sair; a trilha guarda só tipo e contagem	o log de governança virar mais uma cópia do dado crítico
Conteúdo on-premise	detecção e Nível 1 rodam na máquina/servidor; só o resíduo ambíguo sobe	dado da empresa sair do perímetro
Identidade confiável	o usuário é lido do SO no servidor — a página não decide quem é	atribuição falsa de quem usou a IA
Isolamento de rede	núcleo em VLAN sem saída; só a DMZ de notificação fala com fora	exfiltração pelo próprio sistema de governança
Agente travado por senha	pausar/desinstalar exige senha (PBKDF2-SHA256)	o usuário comum desligar o monitoramento
LGPD embutida	detecta dado pessoal em IA pública e marca a obrigação de privacidade (achado A-02)	exposição silenciosa de dado pessoal
MITM opt-in e avisado	interceptação TLS só com aval de Segurança, CA corporativa e aviso ao usuário	vigilância de conteúdo sem consentimento

Quando a IA para e chama o humano

- **Baixa confiança da regra** (R07 validar finalidade; R13 revisar Interna): o julgamento é do conteúdo — vai a revisão, não é decidido sozinho.
- **Risco crítico**: a política encaminha a Compliance/Segurança; a IA evidencia, a pessoa decide.
- **Achados de auditoria**: realimentam a política — o achado A-06 propõe a regra **R15** que faltava.

`Testes com Inteligência Artificial`

As cinco perguntas, respondidas

01

A resposta está sustentada nos dados ou nas fontes?

Sim. Toda decisão de risco traz a **cadeia de evidência** — a regra acionada, o que os detectores encontraram e, quando há, a assinatura de fingerprint do documento de origem. O LLM só opina com o vocabulário e o contexto da própria base; ele não inventa valores fora dela.

02

A saída atende ao resultado esperado?

Medido, não afirmado: **15/15** dos casos oficiais do gabarito e **98,8%** de concordância de nível com a base. Os dois motores (Python e navegador) batem em **650/650** eventos, então a simulação de impacto não mente.

03

Como a solução reage quando não possui informação suficiente?

Ela **não força uma decisão**. Quando a regra não resolve (ex.: R07 pede validar a finalidade, R13 manda revisar Interna), o nível fica **provisório** e o caso é escalado ao LLM ou marcado para revisão — explicitamente, na interface, em vez de fingir certeza.

04

Existem respostas incorretas ou sem sustentação?

As divergências não são escondidas: viram **achados**. A auditoria expõe 6 deles (ex.: A-01 regra que pressupõe ferramenta aprovada quando não era; A-04 seis regras nunca acionadas; A-06 lacuna que a política não cobre) e os 7/10 indicadores declarados que não batem com a base. O erro é tratado como resultado, não como falha a esconder.

05

Quando a decisão precisa de revisão humana?

Em três situações: **baixa confiança** da regra (R07/R13), onde o julgamento é do conteúdo; **risco crítico**, que a política encaminha a Compliance/Segurança; e os **achados de auditoria**, que realimentam a política (o achado A-06 propõe a regra R15). A IA prepara e evidencia; a pessoa decide onde importa.

Critério da Semana 4

Aplicabilidade, protótipo e validação

01

Comparação com o processo atual

Manual × alternativa simples × cascata: explicável, barata e a única que vê o uso de IA fora da planilha.

02

Casos representativos não usados no ajuste

15 casos do gabarito (referência externa) + 38 capturas ao vivo; nenhum calibra o motor. 15/15.

03

Acertos, falhas e limitações

98,8%/15-15 de um lado; TLS, paráfrase e paridade de hash do outro — ditas, não varridas para baixo do tapete.

04

Ajustes e comportamento seguro da IA

DNS, LLM local e par prompt↔resposta após os testes; cascata que não decide sem base e escala a humano.